

FICHE DE RÉVISION - GESTION D'INTRUSION

1. ORIGINE CYBERSÉCURITÉ

Premières Menaces (1970-1980)

1971 - Creeper : Premier programme auto-réplicatif sur ARPANET. Bob Thomas (BBN). Message : "I'm the creeper, catch me if you can!". Non malveillant, expérimentation.

1988 - Morris Worm : Premier ver grande échelle. Robert Tappan Morris. 6000 machines (10% Internet). Exploitait : sendmail, finger, mots de passe UNIX. Premier incident majeur mondial.

1987 - Premiers Antivirus : Détection virus, signatures statiques, protection locale.

Facteurs Déclencheurs

Interconnexion systèmes (ARPANET vers Internet académique). Standardisation TCP/IP (1983). Militarisation réseaux (Défense US, résilience). Triade CIA : Confidentialité, Intégrité, Disponibilité. Besoin confidentialité : données militaires, universitaires, bancaires.

Premières Réponses (1988)

CERT : Computer Emergency Response Team, suite Morris Worm.

Pare-feu : Filtrage IP/port, contrôle flux, architectures périmétriques.

Authentification : RSA 1977, politiques mots de passe, identification centralisée.

Évolution Chronologique

1990s - Périmétrie : Château fort, pare-feu, DMZ.

2000s - Défense profonde : IDS/IPS, antivirus, segmentation, anomalies.

2010-2020 - Moderne : Zero Trust, Security by Design, Threat Intelligence, DevSecOps.

Actuel : IA/ML détection, cloud-native, XDR (Extended Detection and Response).

2. CONCEPTS FONDAMENTAUX

Détection d'Intrusion - Définition

Processus identification activité malveillante/anormale dans système, réseau, application.

Objectifs : Détecter attaques en cours, identifier comportements suspects, repérer violations politique, réduire MTTD (Mean Time To Detect).

Pourquoi essentiel ? Pare-feu insuffisants, attaques contournent périmètre, APT invisibles semaines, détection = 2ème ligne défense.

Positionnement Kill Chain : Reconnaissance, Exploitation, C2, Mouvement latéral, Exfiltration.

Objectif stratégique : Réactive vers Proactive (détection précoce).

3 Types de Détection

1. Par signature : Règles connues, rapide, efficace attaques connues, inefficace zero-day. Ex : règle Snort scan Nmap.

2. Comportementale (Anomalies) : Modèle comportement normal, écarts statistiques, adaptée APT.

3. IA/Machine Learning : Classification (RF, KNN, CNN, LSTM), patterns complexes, sensible attaques adversariales.

Systèmes de Détection

NIDS : Analyse trafic réseau.

HIDS : Surveillance hôte.

IPS : Prévention inline (bloque).

SIEM : Corrélation & vision globale.

Cycle : Collecte - Analyse - Alerte - Investigation - Réponse

Réponse à Incident - Définition

Ensemble processus organisationnels, techniques, juridiques pour : contenir incident, limiter impact, restaurer systèmes, préserver preuves, éviter récurrence.

Pourquoi critique ? Détection différent de protection totale, compromis peut être actif, temps réaction = impact.

Objectif : Réduire MTTR (Mean Time To Respond).

Cadres : NIST SP 800-61, DGSSI Maroc, ISO/IEC 27035.

Cycle cyber : Détection - Réponse - Éradication - Restauration - REX

Cycle NIST (6 phases)

1. Préparation : Politique IR, Playbooks, SOC, CERT interne.

2. Détection & Analyse : Qualification alerte, Triage L1/L2, forensic, MITRE ATT&CK.

3. Confinement : Isolation machine, Blocage IP/C2, Segmentation, Suspension comptes.

4. Éradication : Suppression malware, Patch, Rotation MDP, Nettoyage persistance.

5. Récupération : Restauration backups, Vérification intégrité, Surveillance renforcée.

6. REX : Analyse causes, MAJ règles IDS, Amélioration playbooks, Sensibilisation.

Rôles SOC : L1 (triage), L2/L3 (investigation), Incident Manager, Forensic, RSSI.

Gestion Vulnérabilités - Définition

Processus continu : Identifier, Évaluer, Prioriser, Corriger, Surveiller faiblesses techniques.

Vulnérabilité : Faiblesse exploitable par menace (CIA).

Pourquoi stratégique ? 80-90% intrusions = vulnérabilités connues. Attaques réussies = patch manquant. Mesure préventive majeure.

Vulnérabilité différent de Menace différent de Exploit : Vulnérabilité = faiblesse technique. Exploit = code/méthode exploitation. Menace = acteur/événement malveillant.

Vulnerability Management (5 étapes)

1. Découverte actifs : Inventaire IT/OT, Shadow IT, Cartographie.

2. Scan vulnérabilités : Nessus, OpenVAS, Qualys, CVE, authentifié/non-auth.

3. Évaluation & Priorisation : Score CVSS, criticité métier, exposition Internet, exploit public - Risk-Based.

4. Remédiation : Patch management, Reconfiguration, Désactivation, Segmentation.

5. Vérification & Reporting : Re-scan, KPI (MTTR vuln, % critiques, conformité patch).

Normes : ISO 27001-A.12.6.1, NIST CSF, DGSSI Maroc.

Sécurité Défensive vs Offensive

Blue Team (Défensive) : Protéger, détecter, répondre, maintenir résilience. Outils : IDS/IPS, SIEM, SOC, EDR. Objectif : Réduire impact attaque. KPI : MTDD/MTTR.

Red Team (Offensive) : Simuler attaquant réel, identifier failles, tester défenses. Outils : Metasploit, Nmap, Cobalt Strike. Objectif : Découvrir faiblesses avant attaquant. KPI : Taux compromission.

Purple Team : Collaboration Blue + Red + Threat Intelligence. Objectif : Améliorer posture sécurité globale.

Cycle amélioration : Red attaque - Blue détecte - Analyse écarts - MAJ règles - Renforcement.

Sûreté de Fonctionnement (FMCD)

Fiabilité (continuité), Maintenabilité (réparation), Confidentialité (non-divulgaration), Disponibilité (accessibilité), Intégrité (non-altération).

Convergence : Cyberattaques menacent disponibilité (DoS), intégrité compromise = défaillances. Approche holistique nécessaire.

Statistiques 2023-2024

93% entreprises subissent cyberattaque | 4,45 M\$ coût moyen violation | 277 jours détection intrusion | 43% attaques ciblent PME

"Il ne s'agit pas de savoir SI vous serez attaqué, mais QUAND."

3. CLASSIFICATION ATTAQUES

Cyber Kill Chain (Lockheed Martin 2011)

7 Phases :

1. Reconnaissance : Scanning, harvesting infos

2. **Weaponization** : Création malware/exploit
3. **Delivery** : Livraison (email, USB, web)
4. **Exploitation** : Déclenchement code
5. **Installation** : Installation malware
6. **Command & Control (C2)** : Canal commande
7. **Actions on Objectives** : Exfiltration, sabotage

Catégories : 1-3 = Intrusion | 4-5 = Incident | 6-7 = Compromission

Intrusion (Tentative)

Tentative accès non autorisé. Peut être bloquée AVANT succès. Détectable par systèmes sécurité. N'implique pas nécessairement impact.

Ex : Scan ports, Brute force SSH, Injection SQL bloquée.

Incident (Impact CIA)

Événement compromettant CIA.

Confidentialité : Vol données clients.

Intégrité : Défacement site web.

Disponibilité : Attaque DDoS.

Compromission (Contrôle Effectif)

Prise contrôle EFFECTIVE système. Persistance attaquant. Accès privilégié obtenu. Capacité action sur système.

Ex : Backdoor actif, Compte admin créé, C2 établi.

Progression Gravité

Intrusion (tentative, bloquable) puis **Incident** (succès, impact) puis

Compromission (contrôle total, persistance)

APT - Advanced Persistent Threat

Attaque sophistiquée, ciblée, prolongée par acteurs étatiques.

Advanced : Techniques sophistiquées, zero-day.

Persistent : Présence longue durée (mois/années).

Threat : Objectifs stratégiques (espionnage, sabotage).

Exemples : APT28, APT29 (Russie), Lazarus Group (Corée du Nord).

POINTS CLÉS À RETENIR

Chronologie

1971 : Creeper | 1977 : RSA | 1983 : TCP/IP | 1987 : Antivirus | 1988 : Morris Worm + CERT

Triade CIA

Confidentialité (accès) | Intégrité (modification) | Disponibilité (accessibilité)

Détection

Signature (connues) | Comportementale (APT) | IA/ML (patterns)

NIDS (réseau) | HIDS (hôte) | IPS (bloque) | SIEM (corrélation)

Réponse NIST (6 phases)

Préparation - Détection - Confinement - Éradication - Récupération - REX

Kill Chain (7 phases)

Reconnaissance - Weaponization - Delivery - Exploitation - Installation - C2 - Actions

Métriques

MTTD (Time To Detect) | MTTR (Time To Respond)

Teams

Blue (défense) | Red (attaque) | Purple (collaboration)